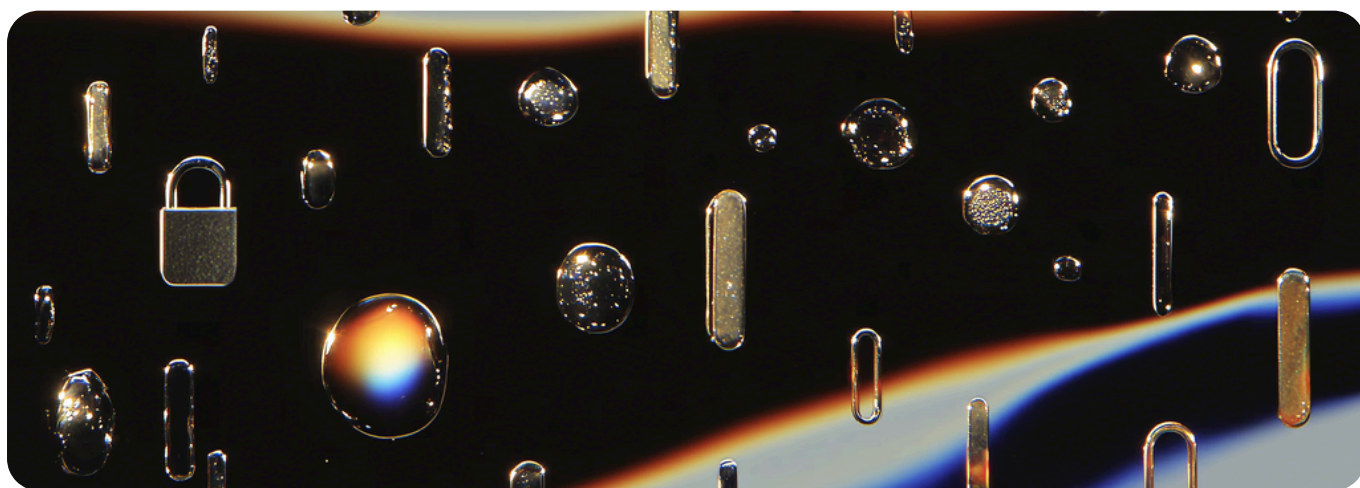


Perplexity открывает исходный код Bumblebee



Стремительное развитие искусственного интеллекта усложнило ситуацию с безопасностью: уязвимости обнаруживаются каждый день.

Последние угрозы все чаще нацелены на программные пакеты, инструменты для разработчиков и локальные среды, на которые полагаются современные инженерные команды, такие как Perplexity. Поэтому обеспечение целостности наших продуктов должно начинаться на более ранних этапах цепочки поставок, чем производство.

Сегодня мы открываем исходный код одного из внутренних инструментов, которые мы используем для защиты систем разработчиков, работающих с Perplexity, Comet и Computer.

Представляем Bumblebee

Bumblebee — это сканер только для чтения, который мы используем для проверки компьютеров разработчиков на наличие уязвимых пакетов,

расширений и конфигураций инструментов искусственного интеллекта во время инцидентов, связанных с цепочкой поставок.

Bumblebee полезен для всех команд, отвечающих за безопасность. Как только становится известно о новой уязвимости, им нужно сразу же узнать, не были ли скомпрометированы какие-либо из их компьютеров.

Повышение безопасности продуктов Perplexity для пользователей начинается с защиты систем разработчиков, на основе которых мы их создаем. Bumblebee — это один из компонентов нашего комплексного процесса обеспечения безопасности, в рамках которого Perplexity Computer помогает отслеживать возникающие угрозы, люди проверяют обновления каталога, а Bumblebee проверяет, присутствуют ли открытые компоненты на конечных устройствах разработчиков.

Сегодня мы открываем исходный код Bumblebee, чтобы любая команда могла использовать тот же уровень безопасности.

От сигнала об угрозе до сканирования конечных устройств

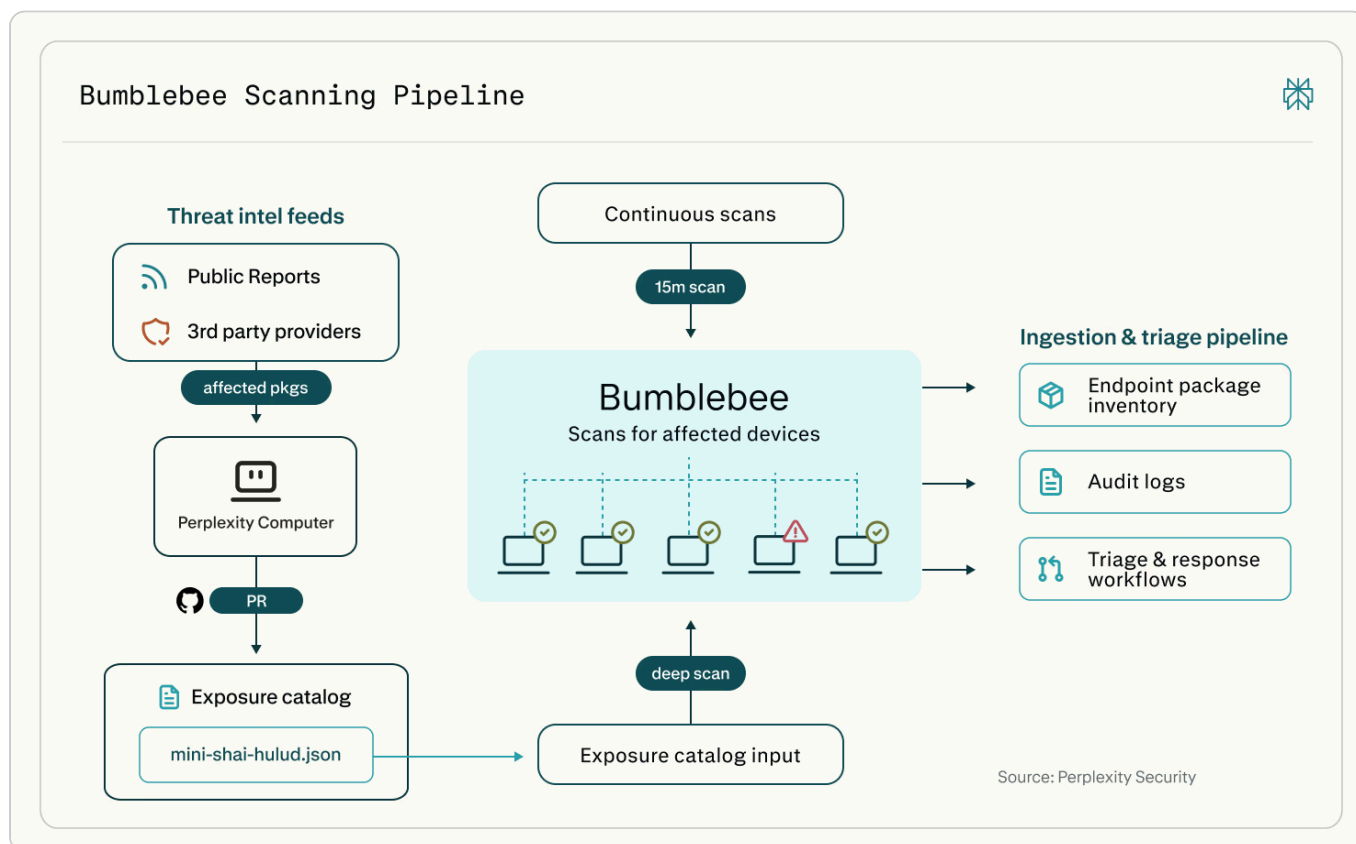
Теперь инженерные организации могут использовать Bumblebee со своими собственными каталогами и процессами проверки. Вот как мы используем Bumblebee внутри компании:

1. Сигнал об угрозе обнаруживается на основе открытых данных, сторонних источников информации или внутренних исследований.
2. Perplexity Computer составляет проект обновления каталога. Сигнал заносится в структурированную запись (экосистема, название, версия), после чего создается пулреквест на GitHub со ссылками на источники.
3. Он проходит проверку человеком, после чего пулреквест объединяется.
4. Bumblebee запускается на конечных устройствах с обновленным каталогом.
5. Результаты передаются команде по обеспечению безопасности.

Bumblebee поддерживает три профиля сканирования, которые определяют, где и насколько широко следует вести поиск:

- Базовый профиль: регулярное сканирование стандартных расположений ноутбуков. Команды планируют его с помощью собственных инструментов управления мобильными устройствами или автопарком.

- **Профиль проекта:** целевое сканирование определенных репозиториев или рабочих пространств.
- **Расширенный профиль:** реагирование на активные инциденты.



Каждое обнаружение можно отследить: видно, какая запись в каталоге привела к созданию файла, когда он был добавлен и какие есть доказательства.

Безопасность начинается с локальной среды разработчика.

Сканеры SBOM и уязвимостей работают с репозиториями и артефактами сборки. Продукты для инвентаризации конечных точек охватывают установленные приложения. Bumblebee работает на ноутбуке разработчика. Он сообщает, установлен ли на этом компьютере определенный пакет, версия, расширение или конфигурация MCP, когда появляется предупреждение о проблемах в цепочке поставок.

Что проверяет Bumblebee

Существующие инструменты с открытым исходным кодом, как правило, охватывают один или два из этих аспектов. Bumblebee охватывает все четыре:

- **Language package managers:** npm, pnpm, Yarn, Bun, PyPI, Go modules, RubyGems, Composer
- **AI agent configs:** MCP
- **Editor extensions:** VS Code-family (VS Code, Cursor, Windsurf, VSCodium)
- **Browser extensions:** Chromium-family (Chrome, Comet, Edge, Brave, Arc) and Firefox

Evaluate exposure safely

Bumblebee is read-only. It reads metadata files directly and never lets potentially compromised tooling run, which prevents the scan from becoming the risk. Making Bumblebee read-only helps avoid issues with install-time code execution.

npm packages can carry postinstall scripts that run automatically the moment npm install touches them. That's how most recent supply-chain worms have spread. A scanner that invokes npm to check for exposure has already triggered the attack it was looking for. Bumblebee prevents this by avoiding:

- **Code execution:** never runs install scripts or lifecycle hooks.
- **Package-manager invocation:** never runs npm, pnpm, bun, or pip.
- **Source-file reading:** never reads application source files; it reads metadata such as lockfiles, manifests, and installed package metadata.
- **Process or network monitoring:** Bumblebee is not an EDR.

Bumblebee is available now as an [open source Go project](#) for macOS and Linux developer endpoints. Security teams can download it, run it against their own catalog of bad versions, and feed the results into whatever response workflow they already use.

Company

Perplexity Enterprise

Brand Guidelines

Careers

Inquiries

[Privacy Policy](#)

[Supply Store](#)

[Security](#)

[Terms & Conditions](#)

Resources

[Getting Started](#)

[Help Center](#)

[Changelog](#)

[Give Feedback](#)

API Platform

[API Overview](#)

[API Models](#)

[API Documentation](#)

[API FAQs](#)

[API Terms of Service](#)

Follow Us

[X \(Twitter\)](#)

[Discord](#)

[Instagram](#)

[Threads](#)

[LinkedIn](#)

[YouTube](#)

